

Stage 0 Sample Reports

Worked examples for a different fictional scenario · Ubuntu Bridge Internship · Cohort 1

Read this first

The four sample reports below are written **for a different fictional company and incident** than the one in your evidence pack. They exist so you can see what a finished D1, D2, D3, and D4 actually look like — the writing style, the citation density, the structure, the level of specificity — without spoiling any of the answers for your Sankofa Digital case.

Your evidence pack is about Sankofa Digital, Q2 2024. These samples are about **BlueWave Telecom, Q4 2023**. Different company, different threat actor, different files, different ticket IDs.

Copy the form. Do not copy the content.

The fictional scenario these samples are written for

- **BlueWave Telecom** — an 800-person Kenyan telecom.
- **Head of Information Security:** Wanjiru Kamau. She re-opened ticket **BWT-29104**, a Q4 2023 alert her predecessor closed as "vendor activity — expected".
- **The intern's predecessor (Tier-1 analyst at the time):** Daniel Otieno.
- **Files in the fictional pack:** `partner-portal.log`, `encoded-blob.txt`, `change-tickets-q4.csv`, `vendor-roster.csv`.
- **Threat actor:** "Hyena Collective" (decoded from one of the four payloads).
- **Initial access:** stolen SSO credentials belonging to a vendor account whose owner had been terminated three weeks earlier but whose access was never revoked.
- **Exfiltration:** customer billing extracts pulled via the partner portal session.
- **Break-point:** ticket BWT-29222, escalated by a junior analyst (Lillian Achieng) who didn't pattern-match to "vendor activity — expected" the way Daniel had.

That is the scenario for the samples. Yours is different. Read on.

D1 — Suspicious-login evidence table (sample)

Sample written for the BlueWave Telecom scenario. Yours is for Sankofa Digital.

Methodology

I read the `partner-portal.log` first, then cross-referenced every entry against `change-tickets-q4.csv` to see which logins had been raised by the SIEM and how the responding analyst had dispositioned each. I then loaded `vendor-roster.csv` to confirm which vendor accounts were active versus terminated during Q4. The encoded payloads in `encoded-blob.txt` were decoded last; one of the four resolved to a threat-actor name that I then back-searched in the `partner-portal.log`.

A login was treated as suspicious if at least one of the following held: the source IP did not match the vendor's documented network range, the account belonged to a roster entry marked terminated, the access fell outside the contracted change window, or the SIEM rule that fired correlated to "e 2 prior alerts the same week. Where the log and the ticket history disagreed, I trusted the log timestamp and treated the ticket disposition as the analyst's interpretation, not ground truth.

Confidence ratings

- **H — High.** Two independent files corroborate; no plausible benign explanation. Example: BWT-29104 (the SSO acceptance from a non-vendor IP on a terminated account).
- **M — Medium.** One file shows it directly; corroboration is plausible but not confirmed within this pack. Example: an OAuth token refresh from a residential ISP that does not appear in the change-ticket history at all.
- **L — Low.** Suspicious by pattern but not by any single line of evidence. Example: a vendor login that fell 4 minutes outside the contracted change window — within tolerance, but worth noting.

Suspicious-login events, Q4 2023 (BlueWave partner portal)

#	Timestamp UTC	Source IP	Account	Why suspicious	Corroborating evidence	Confidence
1	2023-11-14 23:41	102.215.13.4	vendor-ace.ke	SSO acceptance on terminated account, non-vendor IP	partner-portal.log:142; vendor-roster.csv:18 (terminated 2023-10-22); BWT-29104	H
2	2023-11-19 22:08	102.215.13.4	vendor-ace.ke	Repeat from same IP, same account, 5 days later	partner-portal.log:218; BWT-29178	H
3	2023-11-21 03:14	102.215.13.4	vendor-ace.ke	OAuth refresh-token acceptance + billing-CSV export request	partner-portal.log:251–263; change-tickets-q4.csv row 29 (BWT-29222)	H
4	2023-11-22 00:02	102.215.13.4	hyena-collective (decoded)	Threat-actor name appears in payload-3 of encoded-blob.txt	encoded-blob.txt payload 3; partner-portal.log:271	H
5	2023-12-03 23:58	169.150.224.12	vendor-ace.ke	Second IP attempt, same terminated account, blocked by rate-limit	partner-portal.log:412; BWT-29298	M

Commentary under each row in the actual submission. Row 1 is the breach. The IP 102.215.13.4 resolves to a residential ISP, not Ace's documented network. The account vendor-ace.ke was offboarded 23 days earlier. Daniel closed BWT-29104 as "vendor activity — expected", which becomes the dismissal pattern D2 unpacks. Row 3 is the moment customer billing data left the building.

[A real D1 has 8–12 rows. This sample shows 5 for length — yours must hit 8 minimum.]

Pattern summary

The five rows above describe a single attacker (one IP, one account, one threat actor name) returning four times across nine days to the same partner portal, escalating from authentication to OAuth-token theft to data exfiltration. Three of the five events were raised by the SIEM and three of the five were dismissed as routine vendor activity. The dismissal pattern is the throughline.

The row a grader should reread first

Row 3. It is the only row in the table where the attacker's behaviour changed from "lurking" (authentication) to "doing damage" (billing extract). Everything before it is reversible; everything after it is breach disclosure territory. If only one piece of evidence makes it into the Incident Committee report, it is this one.

My next investigative step

Pull the full OAuth token-issuance log for `vendor-ace.ke` between 14 November and 4 December and correlate refresh-token timestamps against the four partner-portal logins above. If the refresh tokens were minted on dates that do not align with vendor-portal logins, that proves a second compromise vector outside what this pack shows.

D2 — Tier-1 dismissal pattern analysis (sample)

Sample for BlueWave. Yours is for Sankofa.

The pattern

Single-analyst dismissal of partner-portal alerts as `disposition: vendor-activity-expected` without cross-correlation against `change-tickets-q4.csv` or the contracted change-window calendar — a structural failure that allowed four separate alert events for the same compromised vendor account to be closed without any cross-reference.

The four tickets that prove the pattern:

- **BWT-29104.** `disposition=vendor-activity-expected; notes="Routine ACE access, ticket closed."`
- **BWT-29178.** `disposition=vendor-activity-expected; notes="Same as BWT-29104. No new info."`
- **BWT-29222.** `disposition=escalated-to-tier-2; notes="Flagged for second review — IP does not match ACE network." (this is the break-point, raised by Lillian Achieng)`
- **BWT-29298.** `disposition=vendor-activity-expected; notes="Vendor rate-limit hit, no further action."`

Per-ticket walkthrough

BWT-29104

What the SIEM raised. Authentication from `102.215.13.4` against `vendor-ace.ke`, an IP not in the Ace partner network range.

Dismissal. `disposition=vendor-activity-expected; notes="Routine ACE access, ticket closed."`

What was missed. `vendor-roster.csv` row 18 shows `vendor-ace.ke` was terminated 22 October 2023 — 23 days before this login. A cross-reference against the roster, which the SIEM does not auto-correlate, would have flipped the dismissal.

What it cost BlueWave. Nine days of undetected lurking and three additional logins from the same actor before the pattern broke. Customer billing CSVs were exported during this window.

BWT-29178

What the SIEM raised. Repeat login from the same IP, same account, five days after BWT-29104.

Dismissal. `disposition=vendor-activity-expected; notes="Same as BWT-29104. No new info."`

What was missed. The "same as" reasoning is the structural failure — a second alert for a closed account on a non-vendor IP is itself the signal, not a duplicate.

What it cost BlueWave. The dismissal validated the prior dismissal, hardening the pattern. The next two alerts (BWT-29222, BWT-29298) inherited the same disposition vocabulary.

[Real D2 has the walkthrough block for every cited ticket. Sample shows two for length.]

Root cause

Of the 42 partner-portal auto-tickets opened in Q4 2023, **31 were closed by the same Tier-1 analyst** (Daniel Otieno — column `closed_by` in `change-tickets-q4.csv`). Of those 31, **27 used the `'vendor-activity-expected'` disposition**. The pattern is not a one-off lapse. It is one analyst's house style.

BlueWave's SOC bench at the time was four analysts on rotating shifts; coverage on the partner-portal queue specifically had collapsed to one rotation slot because the other three analysts had been routed to a different incident

in October. The breach window aligns with the period when Daniel held that queue alone.

Break-point — Lillian Achieng's escalation (BWT-29222)

BWT-29222 broke the pattern because it was closed (escalated, really) by a different analyst. Lillian Achieng had been on the partner-portal queue for two shifts. Without Daniel's pattern-match priors, she opened the alert, checked `vendor-roster.csv` (which Daniel did not), and saw the terminated status. She escalated to Tier-2. Tier-2 issued the rotation that ultimately re-opened the case under Wanjiru.

One concrete procedural recommendation

Any partner-portal SIEM auto-ticket dismissed as `vendor-activity-expected` must be cross-validated against `vendor-roster.csv` and the contracted change-window calendar before close, with a second analyst's signature within 4 hours. Mechanically: the disposition cannot be saved until both the roster check and the calendar check fields are non-empty.

D3 — Business impact and next steps (sample)

Sample for BlueWave. Yours is for Sankofa.

To: BlueWave Telecom Incident Committee

BlueWave Telecom was compromised in Q4 2023 by an external actor calling themselves "Hyena Collective", who used the stolen SSO credentials of a terminated vendor partner to access our partner portal between 14 November and 3 December, and who used that access to export customer billing extracts on at least one confirmed occasion (21 November, 03:14 UTC). The original Tier-1 ticket flagging the activity was closed as routine vendor work; the breach went undetected for nine days, and the dismissal pattern that masked it was not interrupted until a junior analyst escalated outside the original analyst's pattern. We have not yet confirmed the full scope of data exfiltrated or whether the OAuth refresh tokens issued to the compromised account were used elsewhere.

What is at risk

The compromised account, `vendor-ace.ke`, had partner-portal scope including read-access to customer billing CSVs for the Western Region service area. One confirmed export request on 21 November pulled at least 240 customer records (`partner-portal.log:251-263`). Whether the same OAuth refresh tokens were used against other internal APIs is unknown and is the highest open question.

What we know about the attacker: a single residential ISP in Nairobi (102.215.13.4), four logins across nine days, and a self-identifier of "Hyena Collective" decoded from one of the four payloads. The ISP is small and has been associated with one prior incident at a neighbouring telecom in mid-2023. The pattern of returning to the same compromised account daily is unusual for a financially-motivated actor and is more consistent with intelligence collection.

What we cannot yet rule out: persistence beyond the partner portal, lateral movement into the customer-care CRM, and exposure of customer data we have not yet enumerated. This is the basis of Action 1 below.

External reference: NIST CSF function **Detect (DE)** — this incident is principally a detect-side failure. The MITRE technique most directly applicable is **Valid Accounts** (T1078). Full citations are in the appendix.

Three 72-hour actions

Action 1: Rotate SSO secrets and force-revoke all vendor refresh tokens

Owner: Head of Engineering **Deadline:** within 24 hours **Evidence cited:** `partner-portal.log:251-263`; `vendor-roster.csv:18`

Rotate the SSO signing secret for the partner portal and force-invalidate every outstanding OAuth refresh token issued to vendor accounts in the past 90 days. This terminates any session the attacker still holds, and forces the legitimate active vendors back through fresh authentication. **This action does NOT close the question of what data was exfiltrated during the 14 November – 3 December window** — only Action 2 begins to answer that.

Action 2: Quantify exfiltrated customer data and brief Communications Regulatory Authority

Owner: Head of Data Protection **Deadline:** by 18:00 UTC, 72 hours from publication of this memo **Evidence cited:** `partner-portal.log:251-263`; `change-tickets-q4.csv:29` (BWT-29222)

Pull the full export-request log for `vendor-ace.ke` between 14 November and 3 December, enumerate which customer records were touched, and prepare an incident notification to the Communications Authority of Kenya per the Data Protection Act 2019. Regulator notification carries a 72-hour clock; we are already past the discovery point but the clock starts at confirmation of customer-data impact. **This action does NOT remediate the systemic process failure that allowed the dismissal to stand for nine days** — that is the systemic recommendation below.

Action 3: Audit all vendor accounts against the offboarding roster

Owner: Head of Vendor Management **Deadline:** within 48 hours **Evidence cited:** `vendor-roster.csv` (full file); `partner-portal.log:142`

Cross-reference every active vendor account against the termination dates in the vendor roster. Any account belonging to a terminated party that still has active credentials must be disabled today. This closes the specific attack vector that succeeded against us. **This action does NOT prevent the same gap from re-opening when new vendors are offboarded in future** — that is also addressed by the systemic recommendation.

Systemic recommendation

Quarterly vendor-access review with mandatory revocation within 72 hours of any termination, signed off by a second analyst. The review reads `vendor-roster.csv` against the SSO authoritative directory, surfaces every credential whose owning party is no longer with us, and forces revocation before the review can be closed. This recommendation directly addresses the dismissal-pattern documented in D2 around BWT-29104 and BWT-29178: had the roster been the authoritative source rather than a reference Daniel had to remember to check, the pattern could not have hidden the breach. The systemic change is procedural; it does not require a new tool.

Evidence appendix

- `partner-portal.log:142` — SSO acceptance from `102.215.13.4` (BWT-29104 trigger)
- `partner-portal.log:218` — repeat from same IP (BWT-29178)
- `partner-portal.log:251-263` — OAuth refresh + billing export
- `partner-portal.log:271` — threat-actor self-identification
- `vendor-roster.csv:18` — `vendor-ace.ke` terminated 2023-10-22
- `change-tickets-q4.csv:29` — BWT-29222 escalation by Lillian Achieng
- `encoded-blob.txt` payload 3 — decodes to "Hyena Collective"
- NIST CSF function: Detect (DE)
- MITRE ATT&CK: T1078 — Valid Accounts
- Kenya Data Protection Act 2019, Sections 43–45 (notification obligations)

D4 — Judgment essay (sample)

Sample for BlueWave. Yours is for Sankofa.

Part A — The ethics call

Prompt: Your manager tells you to close BWT-29222 because the customer behind the affected partner account is one of BlueWave's largest enterprise contracts, and they will not have their account name dragged into a security review.

I would not close BWT-29222. I would do the following, in order. Within the next hour, I would document the escalation request from the manager in the ticket itself — verbatim, attributed by timestamp — so the record exists regardless of what happens next. Within the next four hours, I would forward the full evidence chain (the four log entries, the roster termination row, the decoded threat-actor name) to the Head of Information Security via the secure email channel, with a one-line subject naming the customer and the suspected exposure scope. I would copy the Head of Legal, because customer-data exposure is no longer just a security decision once the regulator's 72-hour notification clock starts.

What I would not do: close the ticket, retitle it to obscure the customer, verbally agree in the standup to "look at it later", or send the evidence chain to anyone outside the security and legal chain. I also would not raise this in the Slack channel — escalating an ethics issue in a public channel both pre-judges the manager and weakens the formal escalation by making it look reactive.

The ISC2 canon that applies here is **Canon I — Protect society, the common good, necessary public trust and confidence, and the infrastructure**. The compromised account exposed customer billing records of an unknown set

of people; the manager's instruction prioritises one party's brand interest above those individuals' right to be told. The canon orders these for us: society — which includes the customers whose data left the building — comes before the manager's reputational concern.

I escalate next to the Head of Information Security via secure email, copy the Head of Legal, and within 24 hours follow up in person if no acknowledgement arrives. The message I would send is short: "I have evidence of customer data exposure tied to BWT-29222 across four log entries between 14 November and 3 December. I have been asked to close the ticket. I have not. I would like fifteen minutes."

The cost to me is real — the manager will not forget that I went around them. I am taking that cost because the alternative is letting a notification clock expire on data subjects who never consented to that trade.

Part B — The scenario

Prompt: At 04:47 WAT on a Tuesday, you receive a SIEM alert that operations manager `j.kibet` just authenticated via publickey from a residential ISP in Nairobi. Her last successful login was 18:30 the previous day from the office. She is not on the on-call roster. Her offboarding ticket BWT-31207 is open with the note "departure date 12 January, key revocation pending."

I would investigate three things first, in this order. First, the timestamp of her last legitimate office session versus the time gap to the residential-ISP login — `j.kibet`'s normal pattern from the partner-portal logs is daytime-only, so a 04:47 access is itself the anomaly. Second, the status of BWT-31207 — specifically whether the "key revocation pending" date has elapsed, because Lesson 1 from my D1 row 4 is that offboarding paperwork that does not enforce itself becomes the attack surface. Third, the publickey fingerprint — if it matches her registered key, this is harder to dismiss as a forged session; if it does not match, we have something closer to confirmation.

I would escalate at the moment her registered key did not match the presented one — that is the specific trigger. The channel would be the on-call security lead's pager, not an email; pager because we have 30 minutes and email is not synchronous. The message would name the ticket (BWT-31207), the time gap (10 hours from her last office session), and the key-mismatch fact.

I would not lock her account in the first ten minutes. The cost of locking a real operations manager out at 5am because we got nervous is high — she could be travelling on legitimate business and using a personal device. I would not contact her directly either, because if her account is compromised, the call goes to whoever has her phone, which may be the attacker. I would open a fresh ticket rather than appending to BWT-31207, because appending makes the offboarding paperwork look like the cause, when the cause is whoever currently controls her key.

For the next shift, I would leave this note: "BWT-31207 active. `j.kibet` authenticated 04:47 from residential ISP; key fingerprint mismatch (see ticket BWT-XXXX I opened). Security on-call paged 05:02. No lock applied, no direct contact. Morning shift: confirm with `j.kibet` via her registered work number, and only via that number, whether she initiated."

D1 row 4 informed all of this. Once you have watched one terminated vendor account get used as a working credential for nine days, you stop assuming "pending revocation" means "safe".

How to use these samples

- **Read these before you write yours.** Notice the density of citations, the specificity of every claim, the absence of generic phrases.
- **Do not copy the BlueWave content into your Sankofa submission.** The graders know what scenario you are on. A row about 102.215.13.4 in a Sankofa table is a one-way ticket to a flagged-for-AI-review row.
- **Copy the structure freely.** That is what the samples are for.
- **The editable templates** (`stage-0-d1-template.docx`, `stage-0-d2-template.docx`, etc.) are at `/help/templates/`. Start there.

— UBI Programme Team